

Distribuzione delle chiavi: Soluzione moderna



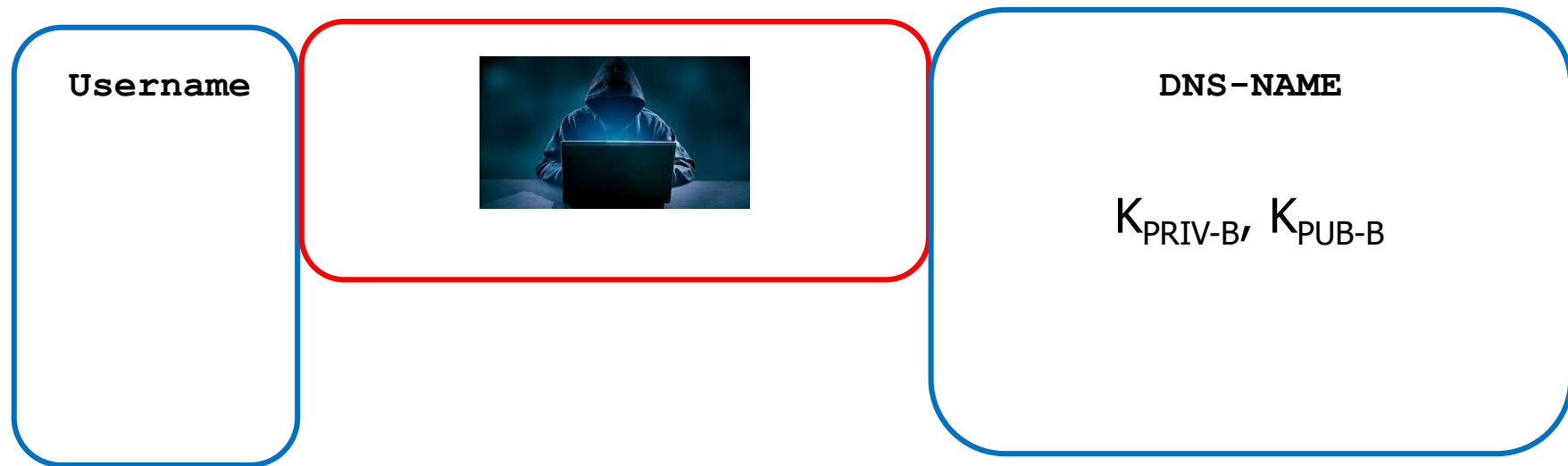
Premessa (I)



- **Subject** (che si deve autenticare crittograficamente)
≡
DNS name

- Generalizzazione ad altri tipi di Subject concettualmente semplice ma complessa da descrivere
 - Subject ≡ codice fiscale
 - Subject ≡ indirizzo email
 - Subject ≡ persona che ricopre un certo ruolo in una certa organizzazione
 - ...

Premessa (II)



- ❑ I Subject che si devono autenticare crittograficamente hanno (K-PRIV,K-PUB)
- ❑ Nostra semplificazione: **solo i Server**
- ❑ Generalizzazione concettualmente semplice ma complessa da descrivere

Certification Authority (I)

Esistono delle entità (**Certification Authority**) che:

1. **Accertano** le **associazioni** tra Subject e KPUB
2. Descrivono le associazioni in file di formato standard (**certificati**):
 1. Subject = "Subject-A"
 2. KPUB = KPUB-A
 3. Issuer = "CA-Y"

Subject = "**www.unicredit.it**"

KPUB = KPUB-X3

Issuer = CA-Y

*KPUB-X3 è la chiave pubblica
di "**www.unicredit.it**"*

Garantisce CA-Y

Subject = "**esse3.units.it**"

KPUB = KPUB-X4

Issuer = CA-Z

*KPUB-X4 è la chiave pubblica
di "**esse3.units.it**"*

Garantisce CA-Z

Certification Authority (II-a)

1. Accertano le associazioni tra Subject e KPUB

```
Subject = "www.unicredit.it"  
KPUB    = KPUB-X3  
Issuer  = CA-Y
```

```
Subject = "esse3.units.it"  
KPUB    = KPUB-X4  
Issuer  = CA-Z
```

- ❑ CA necessita una "prova" che Subject conosce KPRIV compagna di KPUB
- ❑ Quale prova e come accertata da CA:
 - ❑ Dipende dall'applicazione che userà il certificato
 - ❑ Non approfondiamo
- ❑ Seguono due esempi

Certification Authority (II-b)

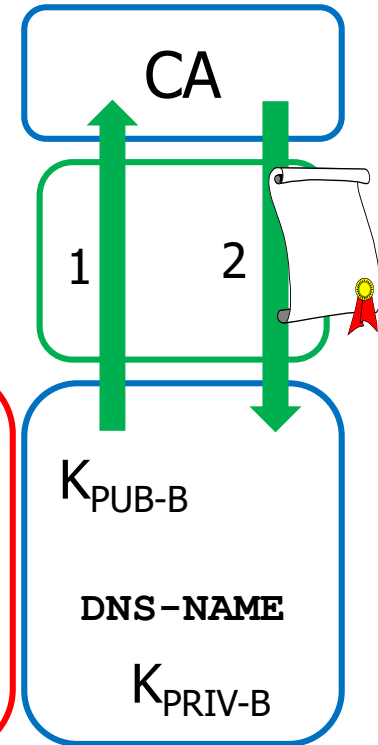
- ❑ Subject $\equiv$ DNS-NAME
- ❑ CA comunica a SubjectFisico che afferma di controllare DNS-NAME un random-value
- ❑ SubjectFisico deve:
 - ❑ Creare un RR DNS-NAME TXT random-value

- ❑ Subject $\equiv$ codice fiscale
- ❑ SubjectFisico con quel codice fiscale deve:
 - ❑ Presentarsi **fisicamente** ad una entità autorizzata dalla CA
 - ❑ Presentare documento di identità e codice fiscale

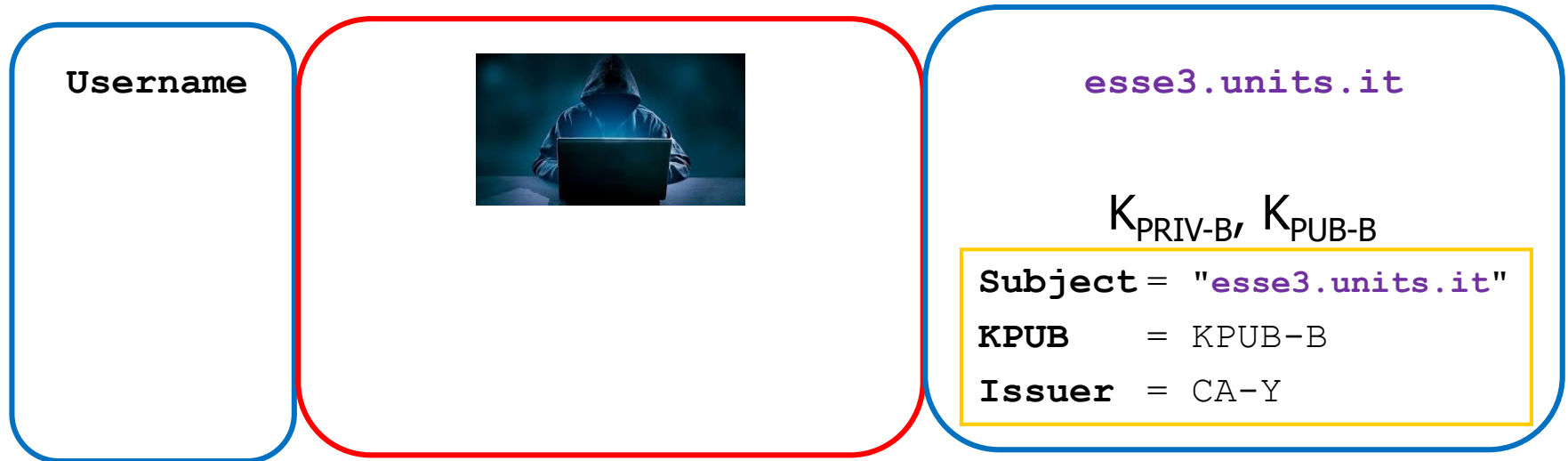
Altro punto di vista



Canale aggiuntivo sicuro
usato **solo una volta** e **solo con la CA**
(per il rilascio del certificato)

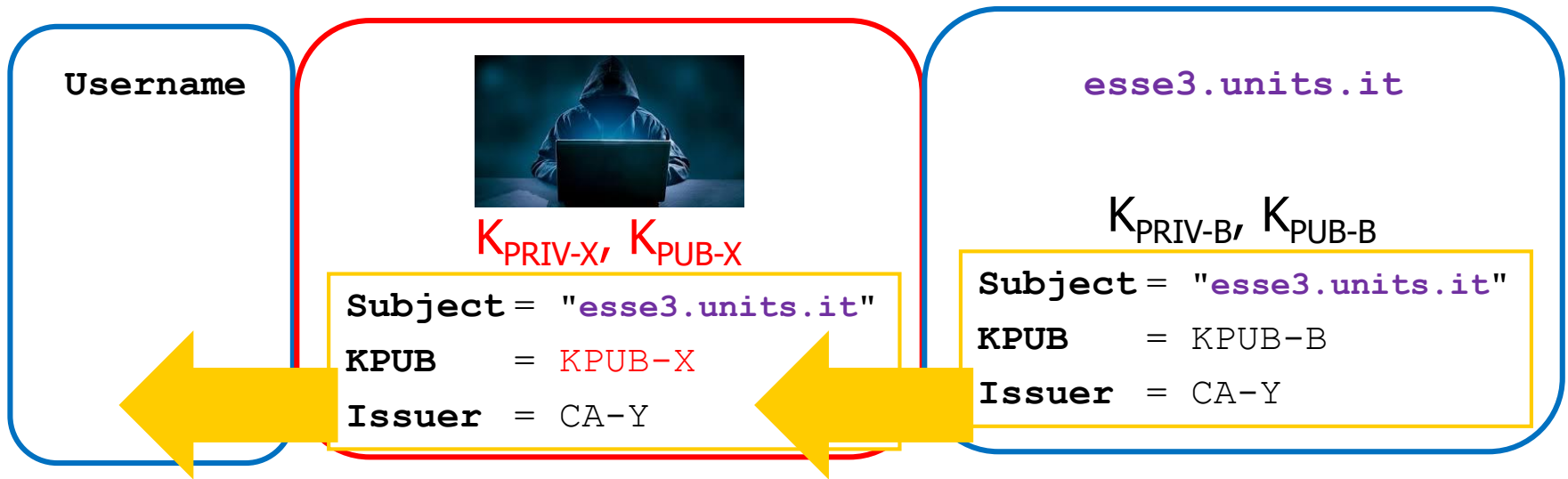


Scenario di partenza (moderno) (I)



- ❑ I Subject che si devono autenticare crittograficamente hanno:
 - ❑ (K-PRIV,K-PUB)
 - ❑ **Certificato** < Subject, KPUB >

Hmmm...(I)



❑ Certificato arriva su canale che:

❑ Non ha autenticità

⇒ Network Attacker potrebbe **falsificarlo**

❑ Non ha integrità

⇒ Network Attacker potrebbe **modificarlo**

Ipotesi magica

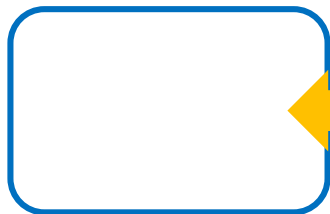
□ Dato un certificato:

1. **Chiunque** può verificare se è:

- **Autentico** Veramente costruito dallo Issuer dichiarato
- **Integro** Non è stato modificato neanche un bit

2. La verifica è **infallibile**

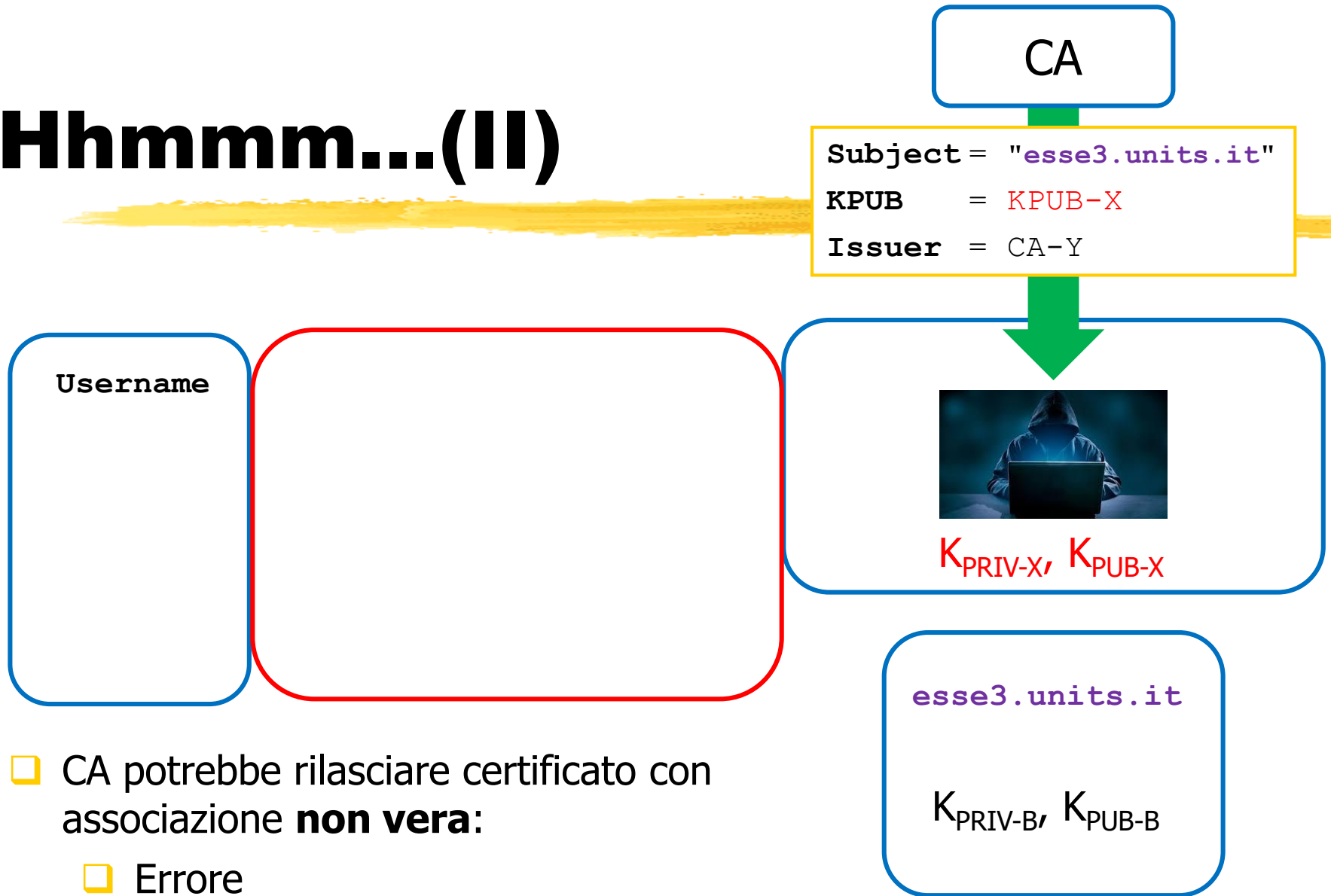
□ **Indipendentemente** dal canale dal quale "esce" il certificato
⇒ Anche se "esce" da un canale **non sicuro**



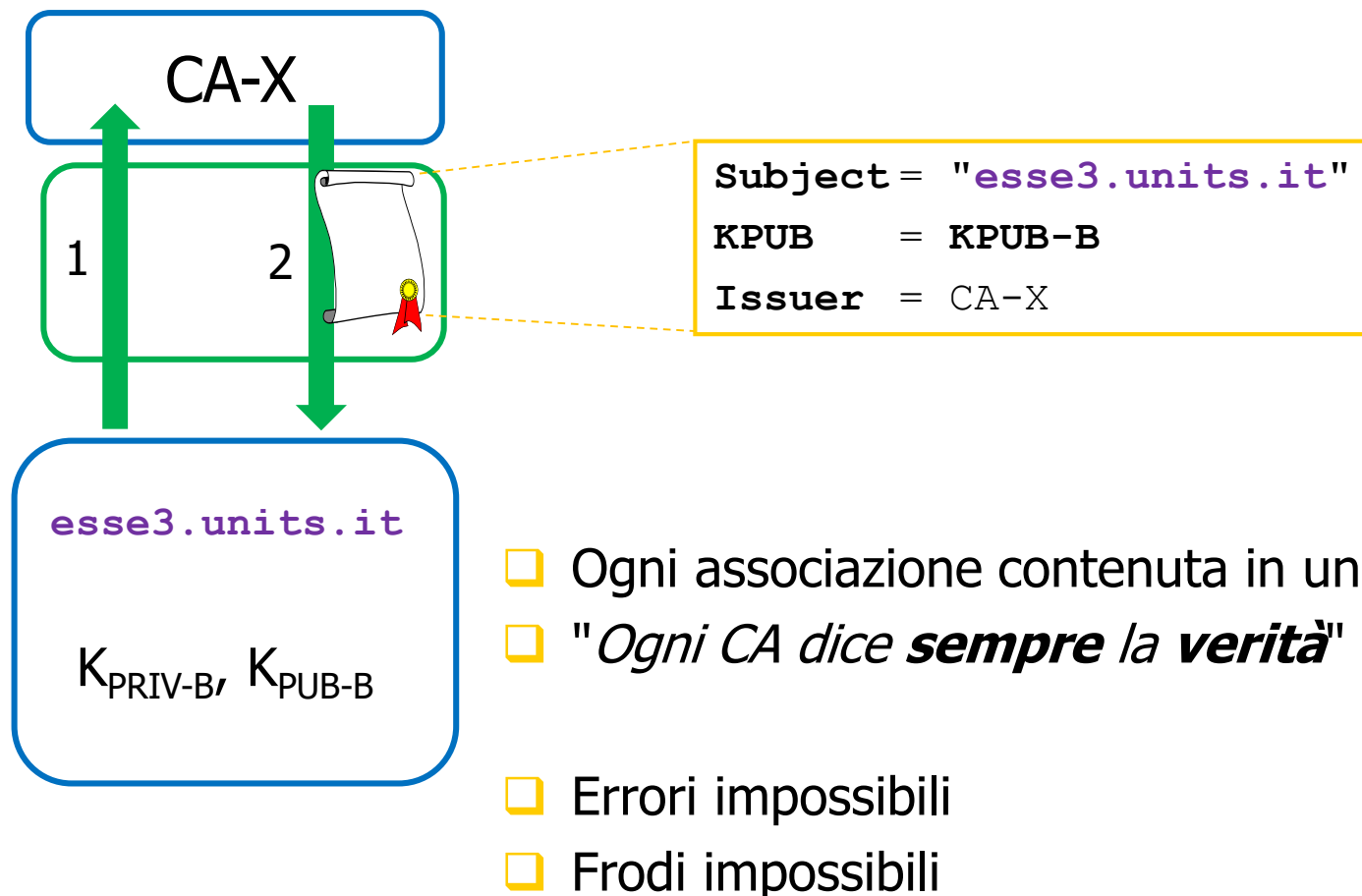
Subject = "s1"
KPUB = KPUB-X1
Issuer = CA-Y



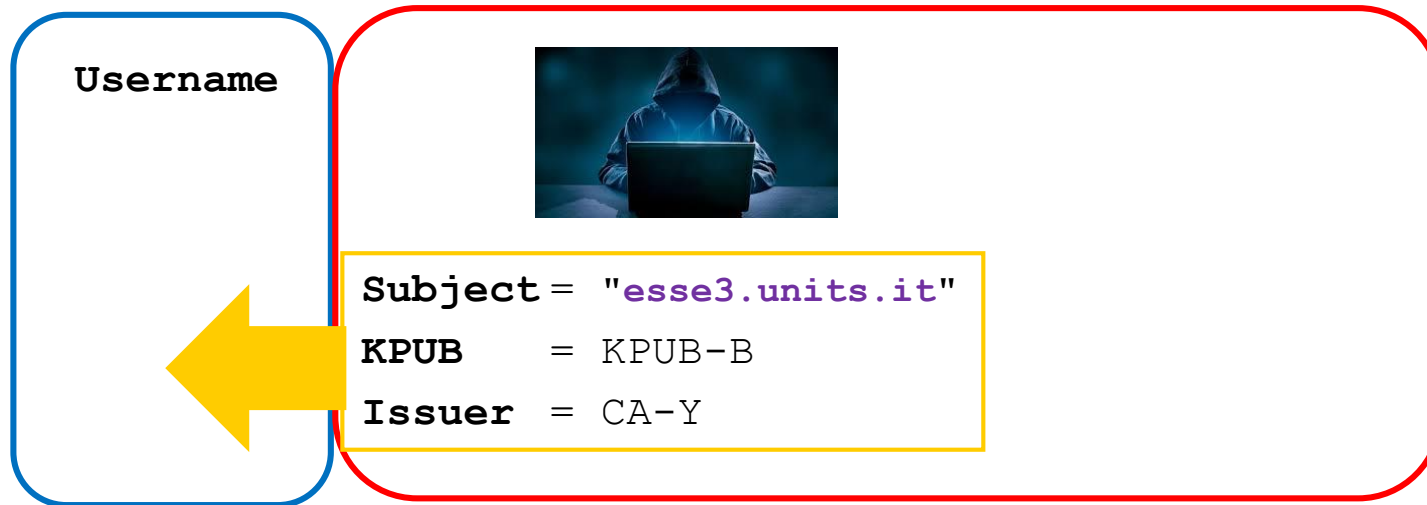
Hmmm...(II)



Atto di fede

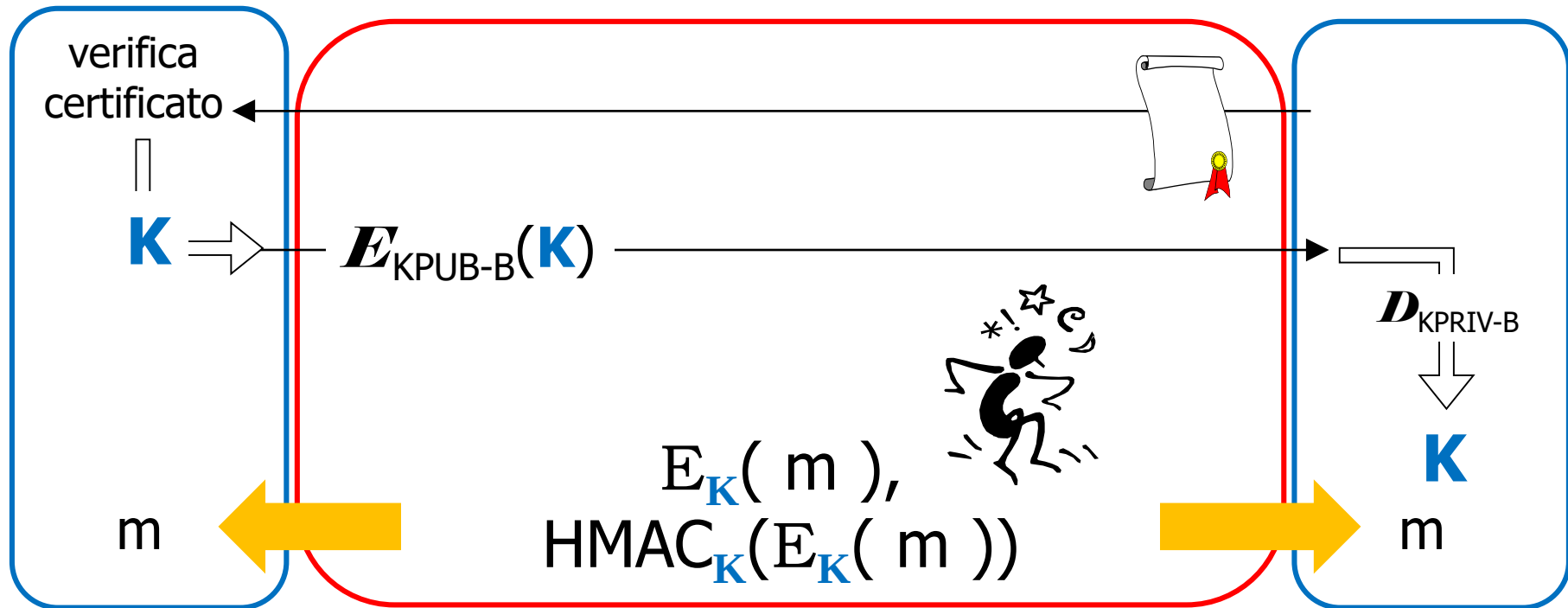


Scenario di partenza (moderno) (II)



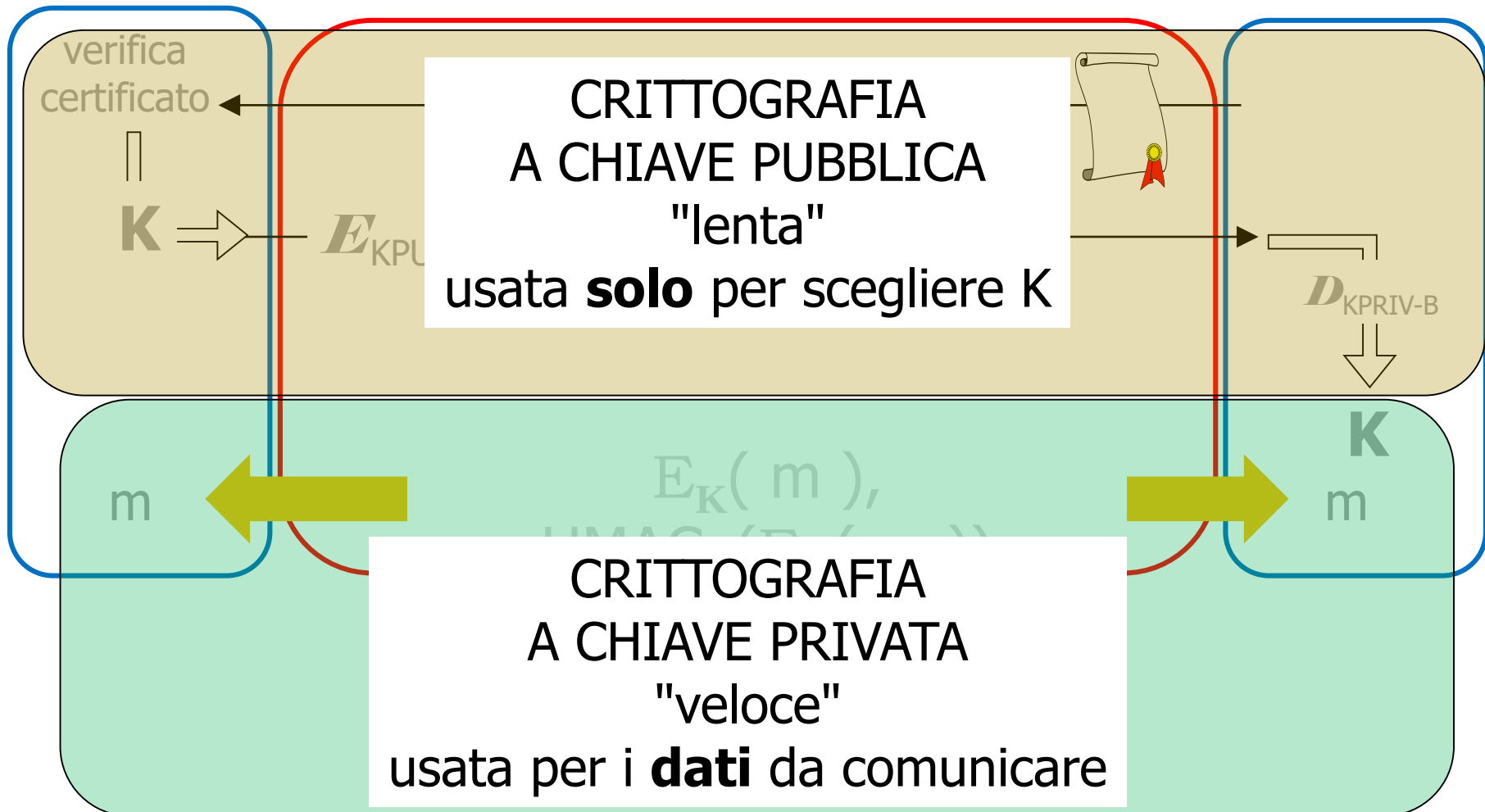
- ❑ Verifica **infallibile** di **autenticità** e **integrità**
- ❑ Contiene la **verità**

"E' fatta!" (davvero...)



- ❑ Scelta della chiave comunicando su canale **non** fidato!
- ❑ Problema irrisolto per **secoli**

NOTA BENE



Dov'è il vantaggio?

- ❑ Canale **non sicuro** reso **sicuro** dalla crittografia a chiave **privata**
- ❑ Necessario condividere chiave tra i due Subject (Username e Server)

1. **Canale aggiuntivo sicuro**
2. **Certificato + Crittografia a chiave pubblica**



E' un vantaggio ENORME

1. Canale aggiuntivo sicuro

- ☐ Necessario per ogni coppia di Subject (**quadratico**)
- ☐ Costo + Latenza **per ogni nuova coppia** di Subject
 - ☐ Ogni primo contatto di Username con Server
 - ☐ Potrebbe essere "eccessivamente costoso" / "non realizzabile" per alcuni Username

2. Certificato + Crittografia a chiave pubblica

- ☐ Necessario **solo** per ogni Server (**lineare**)
- ☐ Costo + Latenza **solo** per ogni nuovo Server
 - ☐ Ogni Server lo usa **solo** una volta, prima di ogni altra comunicazione



There is no free lunch



1. Certificato + Crittografia a chiave pubblica

- ❑ Necessario **solo** per ogni Server (**lineare**)
- ❑ Costo + Latenza **solo** per ogni nuovo Server
 - ❑ Ogni Server lo usa **solo** una volta, prima di ogni altra comunicazione

❑ Indispensabile:

- ❑ Bacchetta magica (per alcune CA)
- ❑ Atto di fede (per quelle CA)

❑ Abbiamo **trasformato** il problema iniziale in **un altro** problema

- ❑ Come si realizza la bacchetta magica? Quale costo?
- ❑ Una CA potrebbe affermare il falso? Quali conseguenze?

Tecnica **GENERALE** (I)



- ❑ **"Tutte"** le applicazioni pratiche della crittografia si basano su varianti di questa tecnica
 - ❑ Canale **non sicuro** reso **sicuro** dalla crittografia a chiave **privata**
 - ❑ Chiave privata trasmessa inizialmente su canale **non sicuro** reso **sicuro** dalla crittografia a chiave **pubblica**
 - ❑ < Subject, KPUB> in **certificato** su canale **non sicuro**

Tecnica GENERALE (II)

- ❑ "Tutte" le applicazioni pratiche della crittografia si basano su varianti di questa tecnica
 - ❑ **TLS** (HTTPS, SMTP/POP over TLS, ...)
 - ❑ SSH
 - ❑ Whatsapp, Whatsapp Web, Signal, Telegram
 - ❑ Skype
 - ❑ GnuPG
 - ❑ Secure Email
 - ❑ Dropbox
 - ❑ Smartphone apps
 - ❑ ...

Osservazioni

- ❑ I certificati sono **pubblici**
- ❑ Non c'è **nulla** di segreto in un certificato
- ❑ E' segreta solo la K-PRIV compagna della K-PUB

```
Subject = "www.unicredit.it"  
KPUB    = KPUB-X3  
Issuer  = CA-Y
```

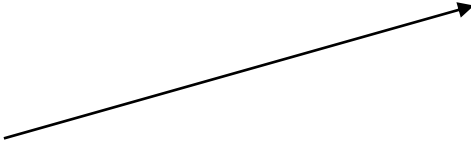
```
Subject = "esse3.units.it"  
KPUB    = KPUB-X4  
Issuer  = CA-Z
```

Formato Certificati

❑ Esistono due standard:

❑ **X509**

Subject: < CN, ON, O, CN >



Common Name
Organizational Unit
Organization
Country

❑ **PGP**

Subject: <Nome, EmailAddress>

❑ Le informazioni essenziali sono le stesse

❑ X509: molto più diffuso (validità legale in Italia)

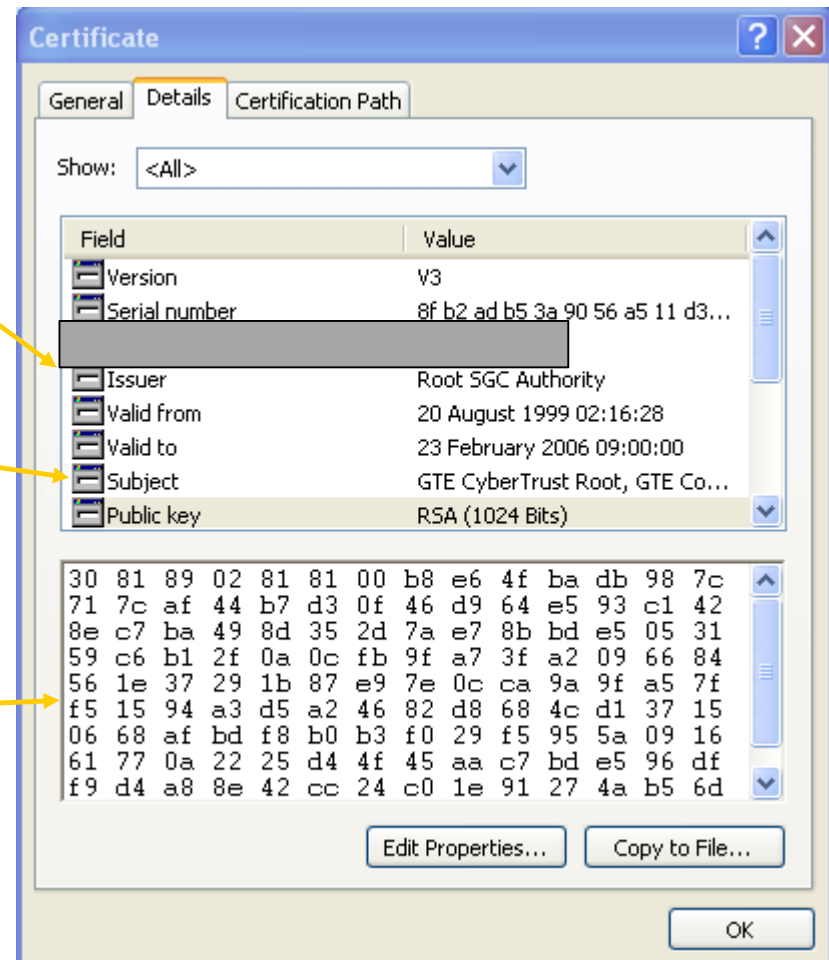
❑ PGP: solo alcuni software (es: GnuPG)

Esempio X509

Issuer

Subject

KPUB

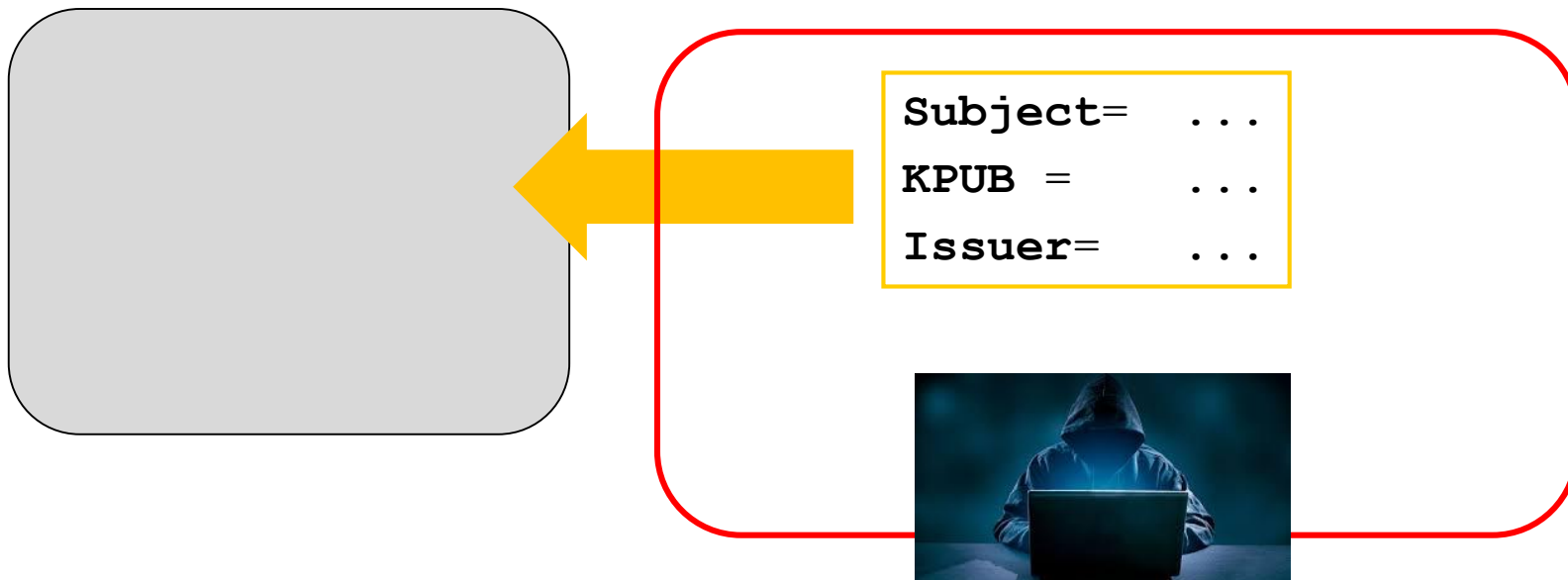


Critt. A chiave pubblica: In pratica



PREMESSA FONDAMENTALE

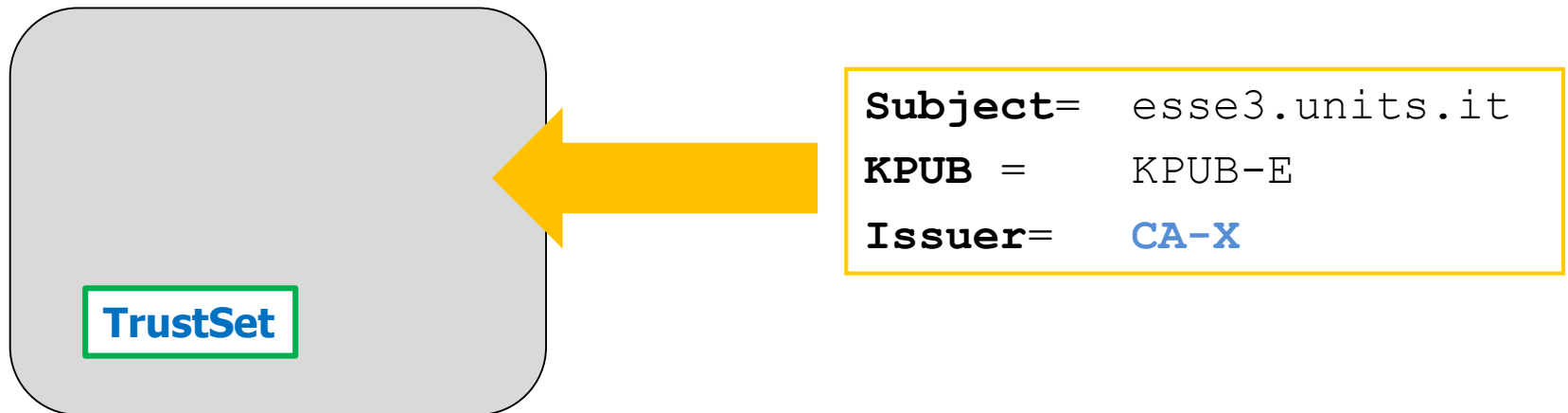
- ❑ Discuteremo certificati che entrano in un dispositivo
- ❑ Arrivano **sempre** su un **canale non sicuro**
 - ❑ Non lo disegniamo esplicitamente ogni volta



Atto di fede:

SOLO per ALCUNE CA

- ❑ Ogni associazione contenuta in un certificato è **vera**
- ❑ *"Ogni CA dice sempre la verità"*
- ❑ **Solo** per le CA il cui nome è in **TrustSet**
 - ❑ Altro punto di vista: **mi fido** solo delle CA nel mio TrustSet



Ipotesi magica:

SOLO per ALCUNE CA

□ Dato un certificato:

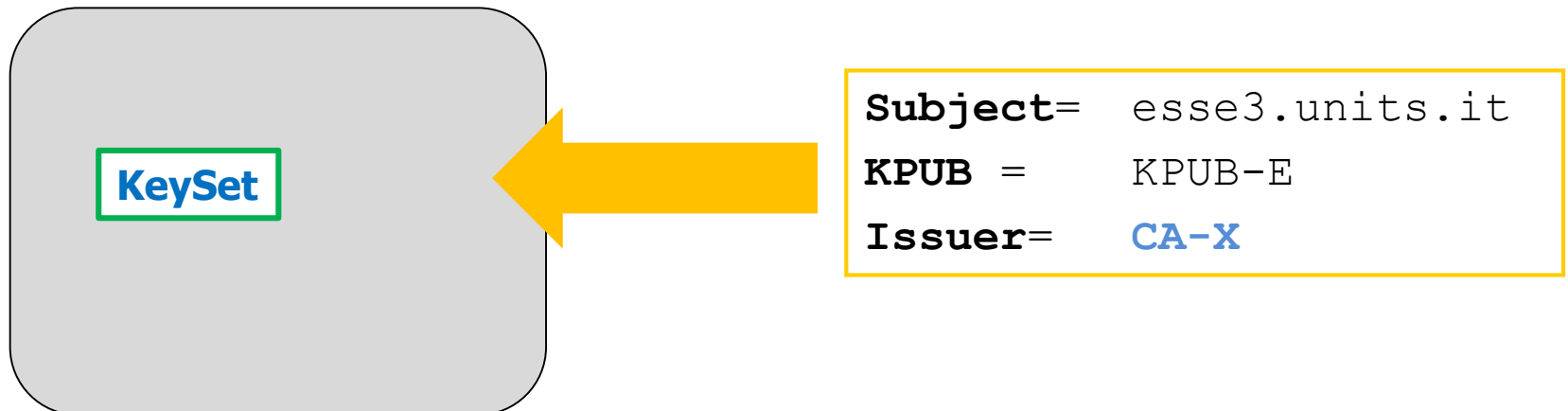
1. Ogni Subject può verificare se è:

□ Autentico: Veramente costruito dallo Issuer dichiarato

□ Integro: Non è stato modificato neanche un bit

2. La verifica è **infallibile**

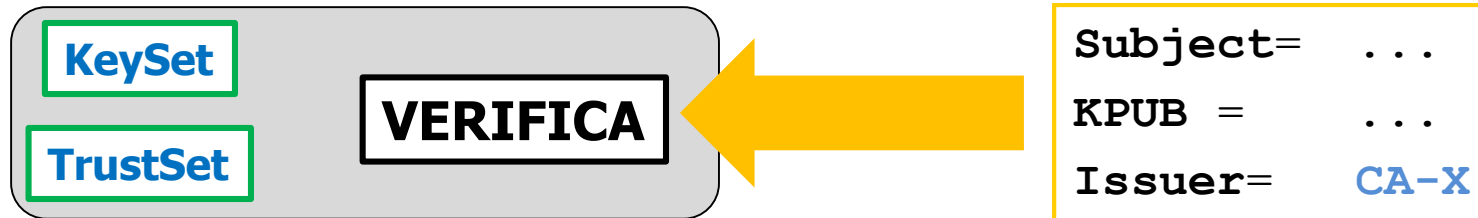
□ **Solo** per le CA il cui nome è in **KeySet**



Configurazione (I-a)

- ❑ **Ogni** sw che usa crittografia a chiave pubblica usa:
- ❑ ...
- ❑ **TrustSet**
 - ❑ Nomi CA di cui si fida
- ❑ **KeySet**
 - ❑ Nomi CA di cui può verificare auth+integr dei certificati
- ❑ Strutture dati **predefinite**
- ❑ Per il momento **non sappiamo come inizializzate**

Verifica certificato (I)



- ❑ **Ogni** sw che **riceve** un certificato lo **verifica**
 1. $CA-X \in \text{TrustSet}$
 2. $CA-X \in \text{KeySet}$
 3. Autentico ed integro (bacchetta magica)
- ❑ Se tutti i test sono superati (certificato **valido**)
- ❑ Allora **usa** il certificato, procedura prosegue
- ❑ Altrimenti **non** usa il certificato, procedura abortisce

Verifica certificato (II)

□ Ogni sw che **riceve** un certificato lo **verifica**

1. $CA-X \in \text{TrustSet}$
2. $CA-X \in \text{KeySet}$
3. ...

□ $CA-X \notin \text{TrustSet} \Rightarrow$ Certificato non valido

□ **Non mi fido** delle affermazioni di CA-X

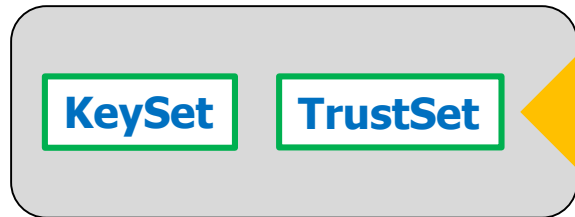
□ NB: non significa che l'associazione sia falsa!

□ $CA-X \notin \text{KeySet} \Rightarrow$ Certificato non valido

□ **Non posso verificare** autenticità e integrità del certificato

□ NB: non significa che non sia autentico o non sia integro

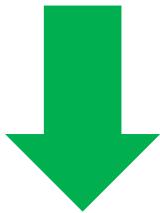
Esempio ("in pratica")



Subject= esse3.units.it
KPUB = KPUB-E
Issuer= CA-E

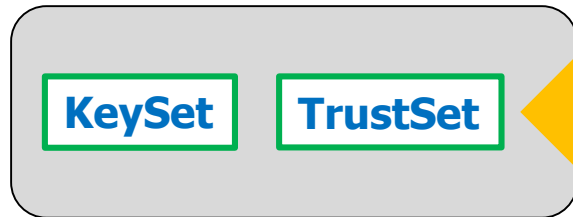


□ Certificato **valido**



□ "KPUB-E è **veramente** la chiave pubblica di esse3.units.it"

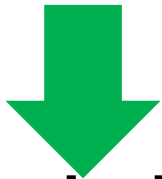
Esempio (ragionamento completo)



Subject= esse3.units.it
KPUB = KPUB-E
Issuer= CA-E



❑ Certificato **valido**



❑ E' **autentico** (veramente costruito da CA-E)

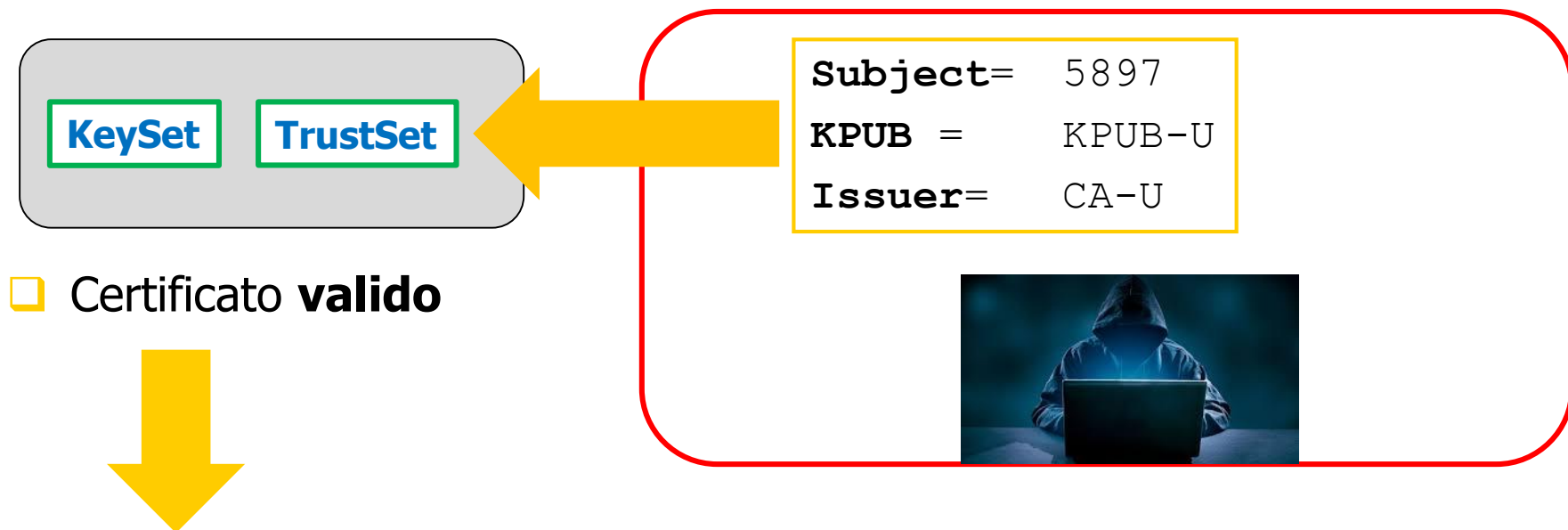
❑ E' **integro** (veramente costruito da CA-E)

❑ CA-E **dice sempre la verità**



❑ "KPUB-E è **veramente** la chiave pubblica di esse3.units.it"

Esempio: Subject "non DNS-NAME"



- "KPUB-U è **veramente** la chiave pubblica di 5897"
- CA-U **ha accertato** che SubjectFisico che controlla il Subject 5897 è associato a KPUB-U
- Cosa significa 5897 e come ha accertato **dipende dall'applicazione**

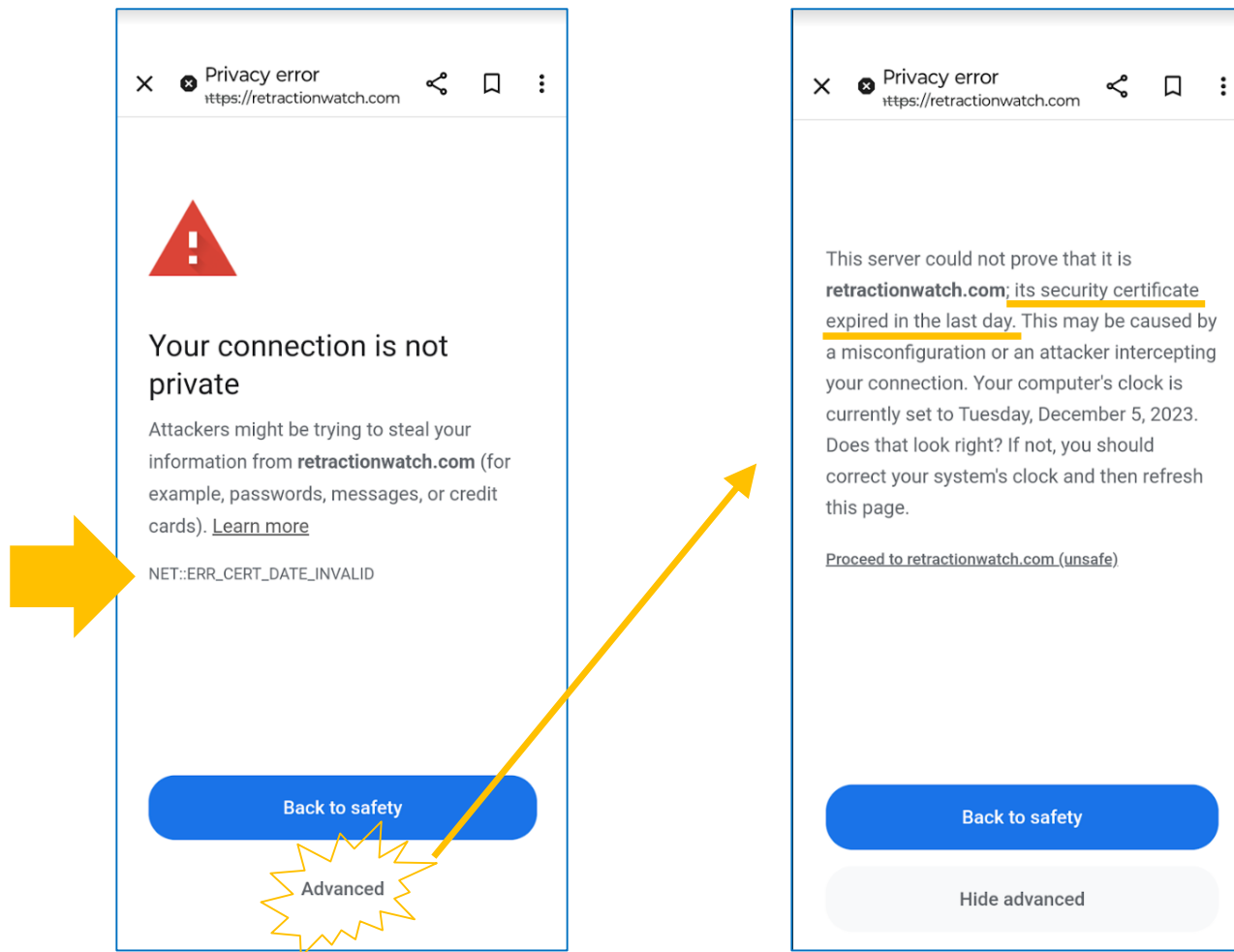
Curiosità (I-a)

- ❑ Ogni sw che **riceve** un certificato lo **verifica**
 1. $CA-X \in \text{TrustSet}$
 2. $CA-X \in \text{KeySet}$
 3. Autentico ed integro (bacchetta magica)

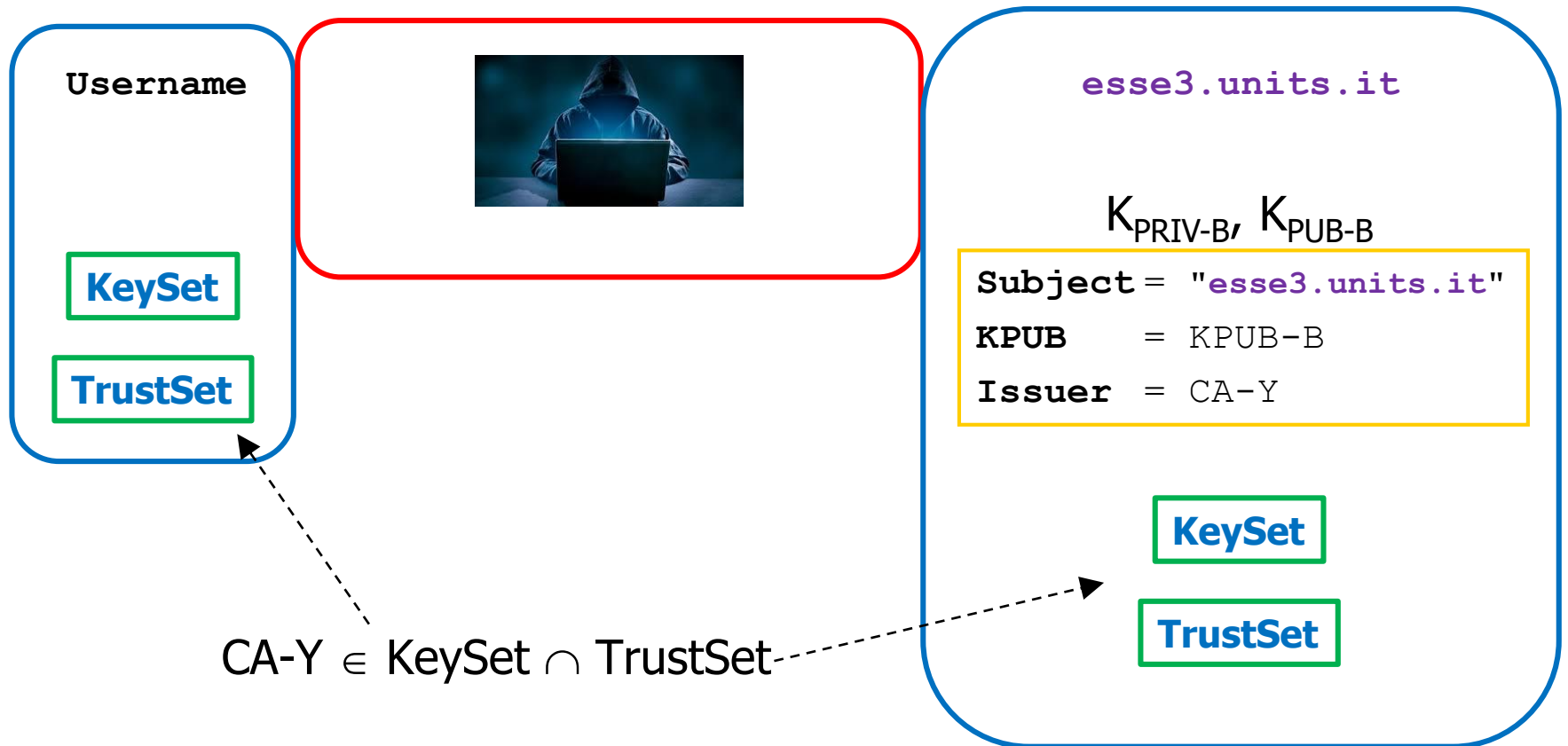
- ❑ In realtà la verifica è molto più complessa (non vediamo)

- ❑ Ogni certificato ha una **scadenza**
 - ❑ Se usato dopo la scadenza allora la verifica fallisce
- ❑ Ogni certificato è rilasciato per **alcuni usi**
 - ❑ Se usato per altri usi allora la verifica fallisce
- ❑ ...

Curiosità (I-b)



Configurazione (I-b)



Configurazione (II-a)



□ **Ogni** sw che usa crittografia a chiave pubblica usa:

□ **PersonalSet**

□ KPRIV-KPUB e Certificato del Subject che usa il sw

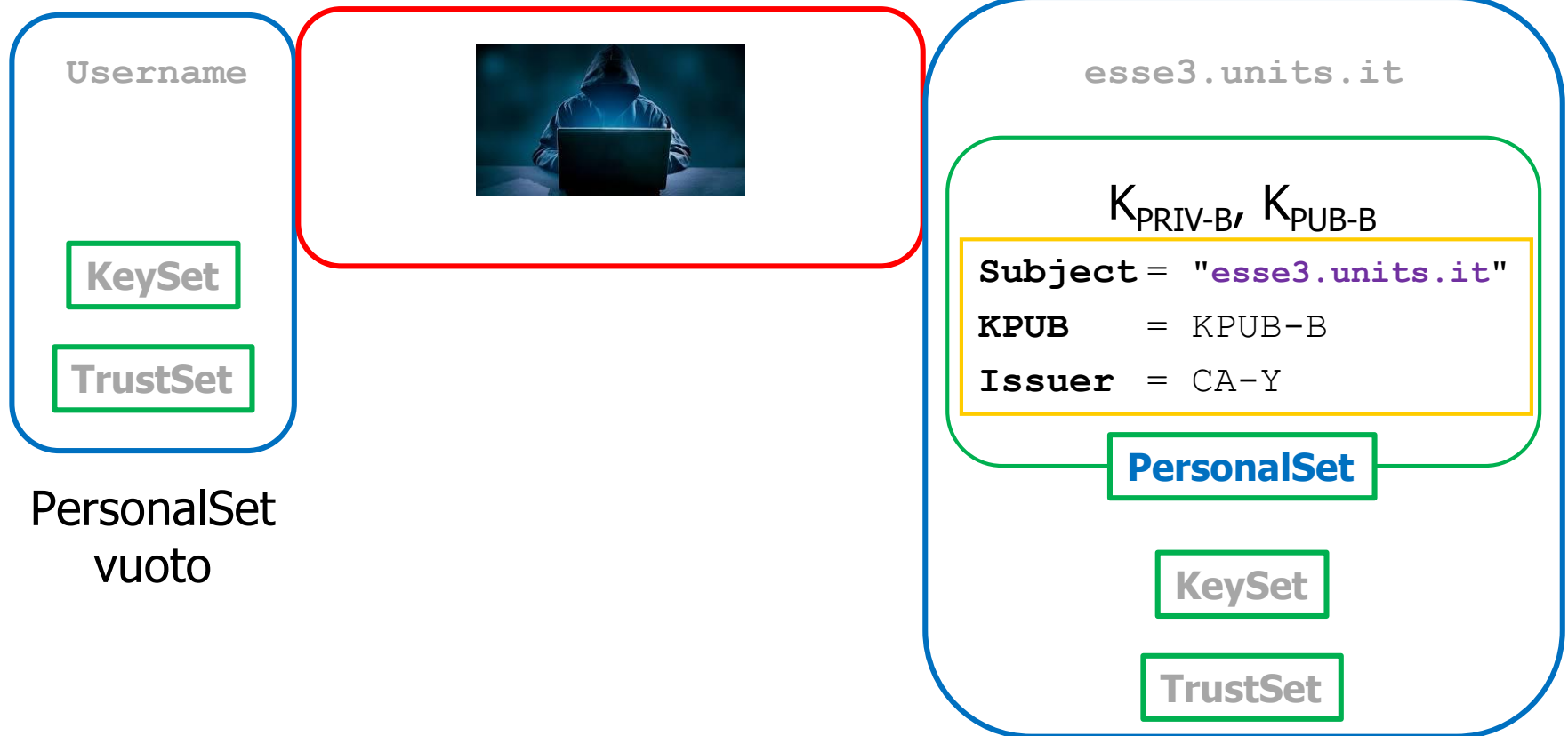
□ **TrustSet**

□ Nomi CA di cui si fida

□ **KeySet**

□ Nomi CA di cui può verificare i certificati

Configurazione (II-b)



Dove sono?



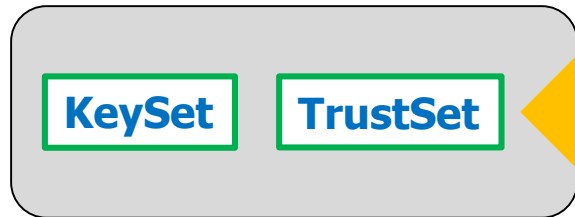
1. PersonalSet
2. TrustSet
3. KeySet

- ☐ Esistono **sempre**
- ☐ **Non** hanno questo nome
- ☐ Spesso sono **mescolati** tra loro
- ☐ Locazione, Nome, Formato dipendono dal sw/s.o.
(vedremo)

Certificato Non Valido



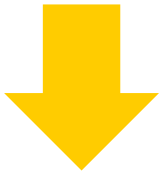
Certificato Non Valido



```
Subject=  esse3.units.it  
KPUB  =   KPUB-E  
Issuer=   ...
```



- ❑ $\text{Issuer} \notin \text{KeySet} \cap \text{TrustSet}$
- ❑ Certificato **non valido**



- ❑ Non posso verificare autenticità ed integrità
- ❑ Non mi fido delle affermazioni dello Issuer
- ❑ **Nessuna garanzia:** Può essere vero o può essere falso

Certificato Non Valido: Cosa succede?



☐ SW

- ☐ Necessita associazione Subject-KPUB
(riceve Certificato per Subject)
- ☐ Certificato **non è valido**

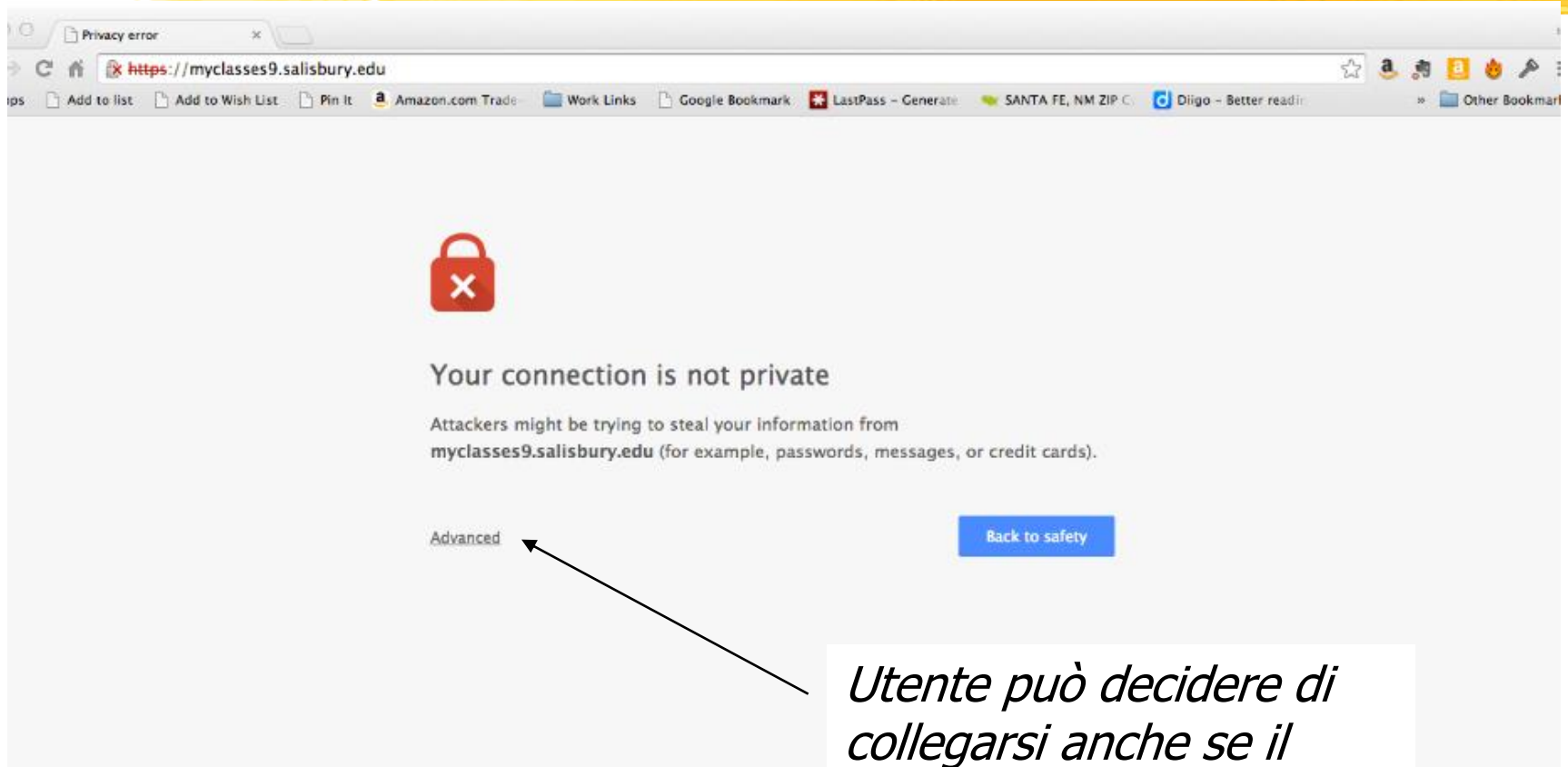
☐ Configurazione SW poco frequente:

- ☐ SW abortisce esecuzione

☐ Configurazione SW molto frequente:

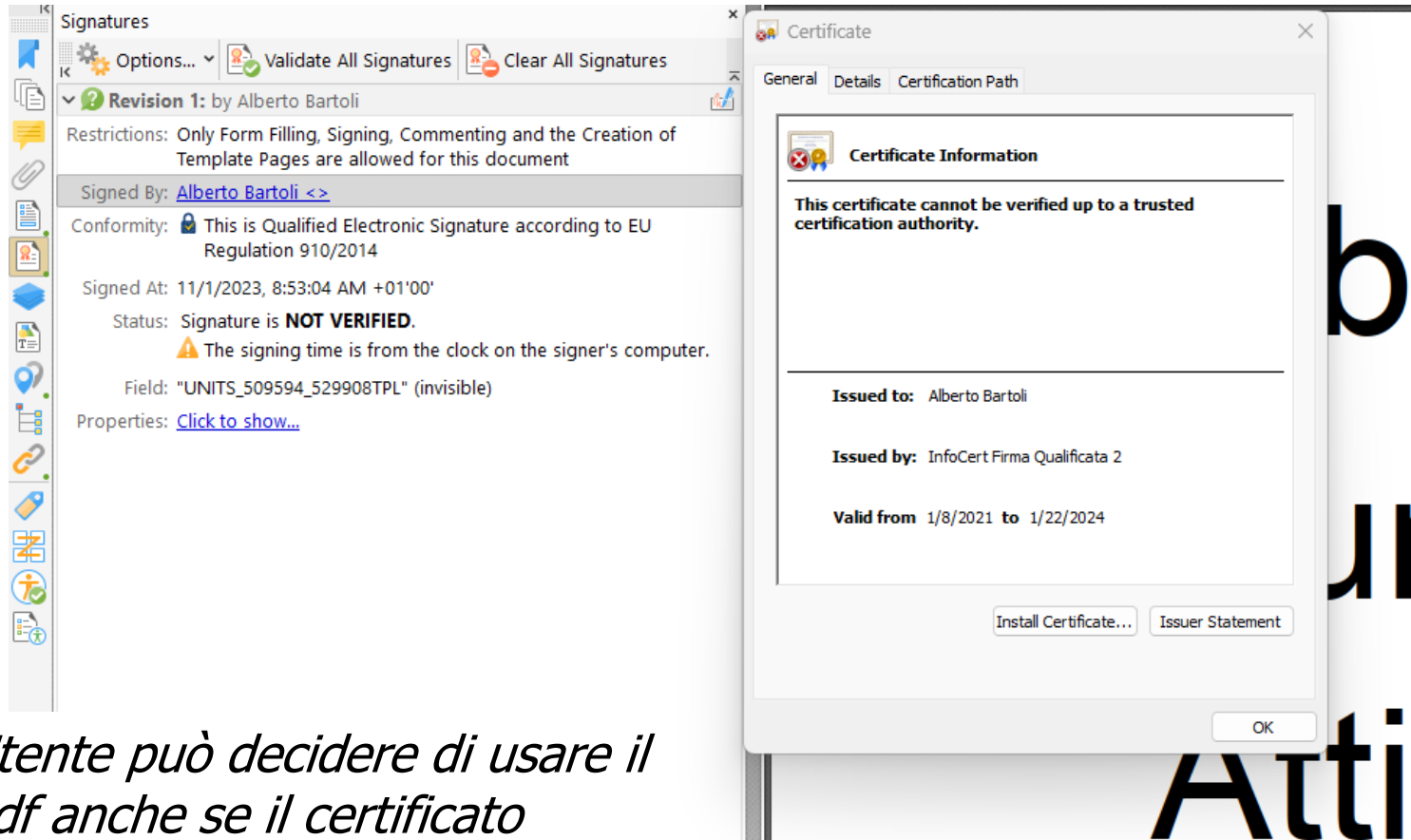
1. SW informa Utente e chiede cosa fare
2. Utente può decidere di usare il certificato
(o di proseguire esecuzione senza usarlo)

Esempio (HTTPS)



Utente può decidere di collegarsi anche se il certificato non è valido

Esempio (Firma Digitale PDF)



Utente può decidere di usare il pdf anche se il certificato non è valido

Importante

❑ $\text{Issuer} \notin \text{KeySet} \cap \text{TrustSet}$

❑ Certificato **non valido**

❑ Non è valido perché non è verificabile dal sw che lo riceve

❑ Valido / Non valido **non** è una proprietà **intrinseca al certificato**

❑ Dipende **da chi deve usarlo**

❑ Può essere valido per qualcuno e non valido per qualcun altro

Subject= esse3.units.it

KPUB = KPUB-E

Issuer= ...